Challenge 4 — Manomissione Input (SSRF + CORS)

1. Scenario

Nella pagina di scrittura articolo di *The Aulab Post* è presente un componente Livewire (`LatestNews`) che suggerisce notizie tramite NewsAPI, selezionabili da un menu a tendina. Ogni `<option>` della select conteneva, come `value`, l'URL completo della chiamata esterna (comprensivo di API key in chiaro). Poiché il valore arrivava interamente dal client, era possibile alterarlo tramite "Ispeziona elemento" per puntare a una risorsa interna non raggiungibile dall'esterno: la Financial App (`internal.finance:8001`), contenente dati finanziari sensibili (saldi, transazioni, numeri di carta di credito).

3. Attacco

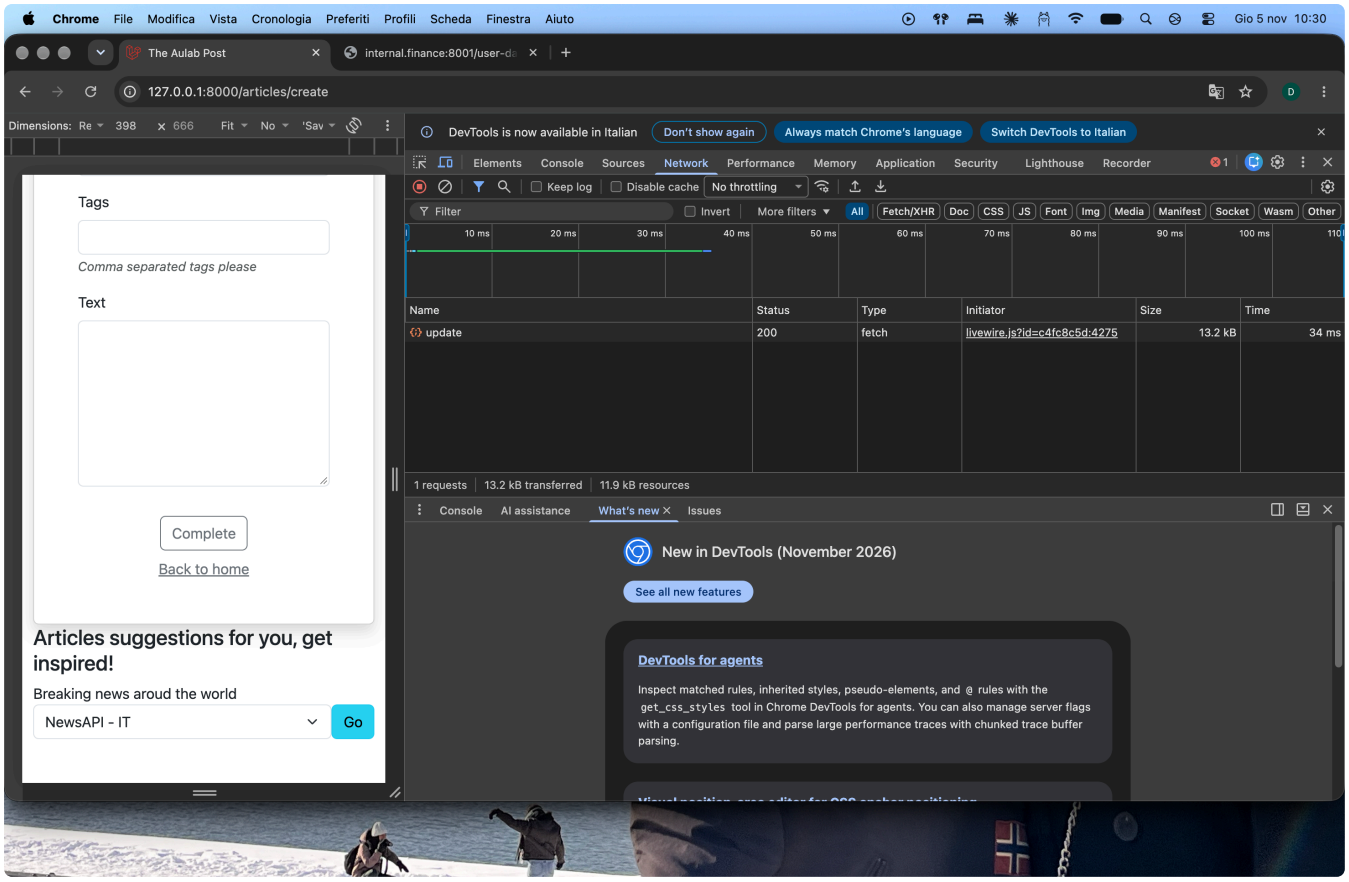
1. Nella select "Breaking news around the world", tramite DevTools, è stato modificato il `value` di una `<option>` sostituendolo con:

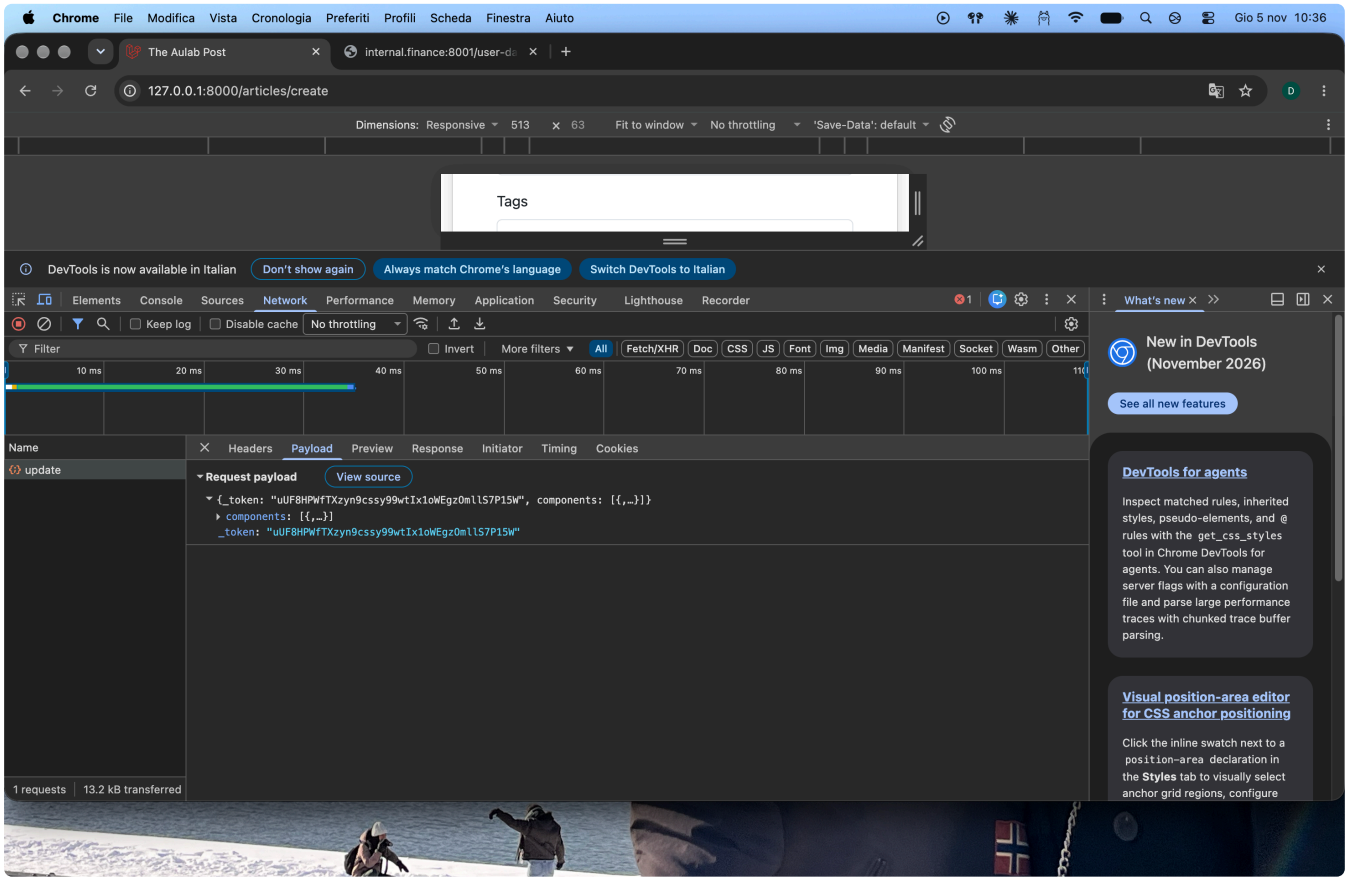
```
<option value="http://internal.finance:8001/user-data.php">NewsAPI - IT</option>
```

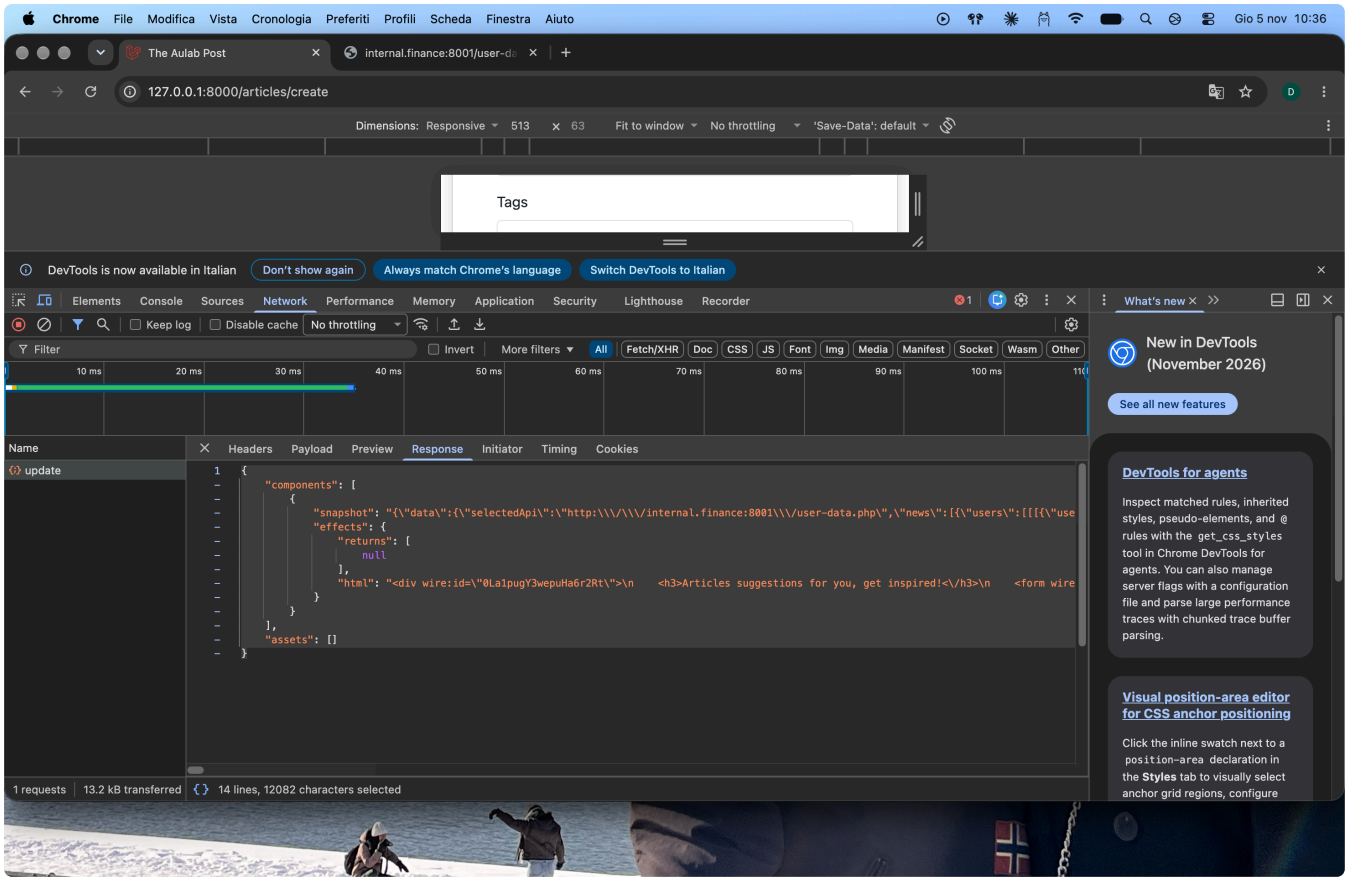
2. Selezionata la voce manomessa e cliccato "Go".
3. Nel tab Network, la richiesta Livewire `update` (fetch, 200, 13.2 kB) conteneva nello snapshot l'intero dump della Financial App: 20 utenti con `account_balance`, cronologia `transactions` e, per ciascuno, `credit_card` completo di numero, scadenza e CVV in chiaro.

Verifica attacco riuscito: screenshot della risposta `update` con i dati finanziari esfiltrati (allegato).

> Nota tecnica: a differenza di quanto previsto a lezione (dati codificati in base64), in questo caso il JSON è tornato già leggibile in chiaro — exfiltration ancora più diretta.


Chrome File Modifica Vista Cronologia Preferiti Profili Scheda Finestra Aiuto
Gio 5 nov 10:30
The Aulab Post
internal.finance:8001/user-da
127.0.0.1:8000/articles/create
Tags
Comma separated tags please
Text
Complete
Back to home
Articles suggestions for you, get inspired!
Breaking news aroud the world
NewsAPI - IT
Go
DevTools is now available in Italian
Don't show again
Always match Chrome's language
Switch DevTools to Italian
Elements Console Sources Network Performance Memory Application Security Lighthouse Recorder
Keep log
Disable cache
No throttling
Filter
Invert
More filters
All Fetch/XHR Doc CSS JS Font Img Media Manifest Socket Wasm Other
Name Status Type Initiator Size Time
update 200 fetch livewire.js?id=c4fc8c5d:4275 13.2 kB 34 ms
1 requests 13.2 kB transferred 11.9 kB resources
Console AI assistance What's new Issues
New in DevTools (November 2026)
See all new features
DevTools for agents
Inspect matched rules, inherited styles, pseudo-elements, and @ rules with the get_css_styles tool in Chrome DevTools for agents. You can also manage server flags with a configuration file and parse large performance traces with chunked trace buffer parsing.


Chrome File Modifica Vista Cronologia Preferiti Profili Scheda Finestra Aiuto
Gio 5 nov 10:36
The Aulab Post
internal.finance:8001/user-da
127.0.0.1:8000/articles/create
Dimensions: Responsive 513 x 63 Fit to window No throttling 'Save-Data': default
Tags
DevTools is now available in Italian
Don't show again
Always match Chrome's language
Switch DevTools to Italian
Elements Console Sources Network Performance Memory Application Security Lighthouse Recorder
Keep log
Disable cache
No throttling
Filter
Invert
More filters
All Fetch/XHR Doc CSS JS Font Img Media Manifest Socket Wasm Other
Name
update
Headers Payload Preview Response Initiator Timing Cookies
Request payload
View source
{_token: "uUF8HPWfTXzyn9cssy99wtIx1oWEgzOmllS7P15W", components: [{,…}]}
components: [{,…}]
_token: "uUF8HPWfTXzyn9cssy99wtIx1oWEgzOmllS7P15W"
1 requests 13.2 kB transferred
What's new
New in DevTools (November 2026)
See all new features
DevTools for agents
Inspect matched rules, inherited styles, pseudo-elements, and @ rules with the get_css_styles tool in Chrome DevTools for agents. You can also manage server flags with a configuration file and parse large performance traces with chunked trace buffer parsing.
Visual position-area editor for CSS anchor positioning
Click the inline swatch next to a position-area declaration in the Styles tab to visually select anchor grid regions, configure



4. Mitigazione

Sono stati modificati tre file, applicando una difesa a più livelli (*defense in depth*).

a) `App/Livewire/LatestNews.php` — l'URL non arriva più dal client. Refactoring completo: la select ora invia solo un codice paese (`it` / `gb` / `us`), non più un URL. Il componente mantiene una mappa server-side (`COUNTRY_ENDPOINTS`) che associa ogni codice all'endpoint NewsAPI corretto; l'API key, prima hardcoded e visibile nell'HTML, è stata spostata in `.env` (`NEWSAPI_API_KEY`) e letta via `config('services.newsapi.api_key')`. Come difesa aggiuntiva restano un'allowlist sugli host ammessi (`newsapi.org`) e un controllo anti DNS-rebinding (`gethostbyname` + `FILTER_FLAG_NO_PRIV_RANGE | FILTER_FLAG_NO_RES_RANGE`) prima di effettuare la richiesta.

b) `App/Services/HttpService.php` — controllo sul ruolo. Anche se `internal.finance` è nominalmente tra i domini conosciuti dal servizio HTTP generico (usato per altre funzionalità admin), è stato aggiunto un controllo esplicito: se l'host richiesto è `internal.finance` e l'utente autenticato non ha `is_admin = true`, la richiesta viene bloccata prima di partire (`'Accesso non autorizzato'`).

c) `config/cors.php` — configurazione ristretta. Sostituiti i wildcard con valori espliciti:

Direttiva	Prima	Dopo
allowed_origins	`['*']`	`['http://127.0.0.1:8000', 'http://cyber.blog:8000']`
allowed_methods	`['*']`	`['GET', 'POST', 'PUT', 'DELETE']`
allowed_headers	`['*']`	`['Content-Type', 'Authorization']`

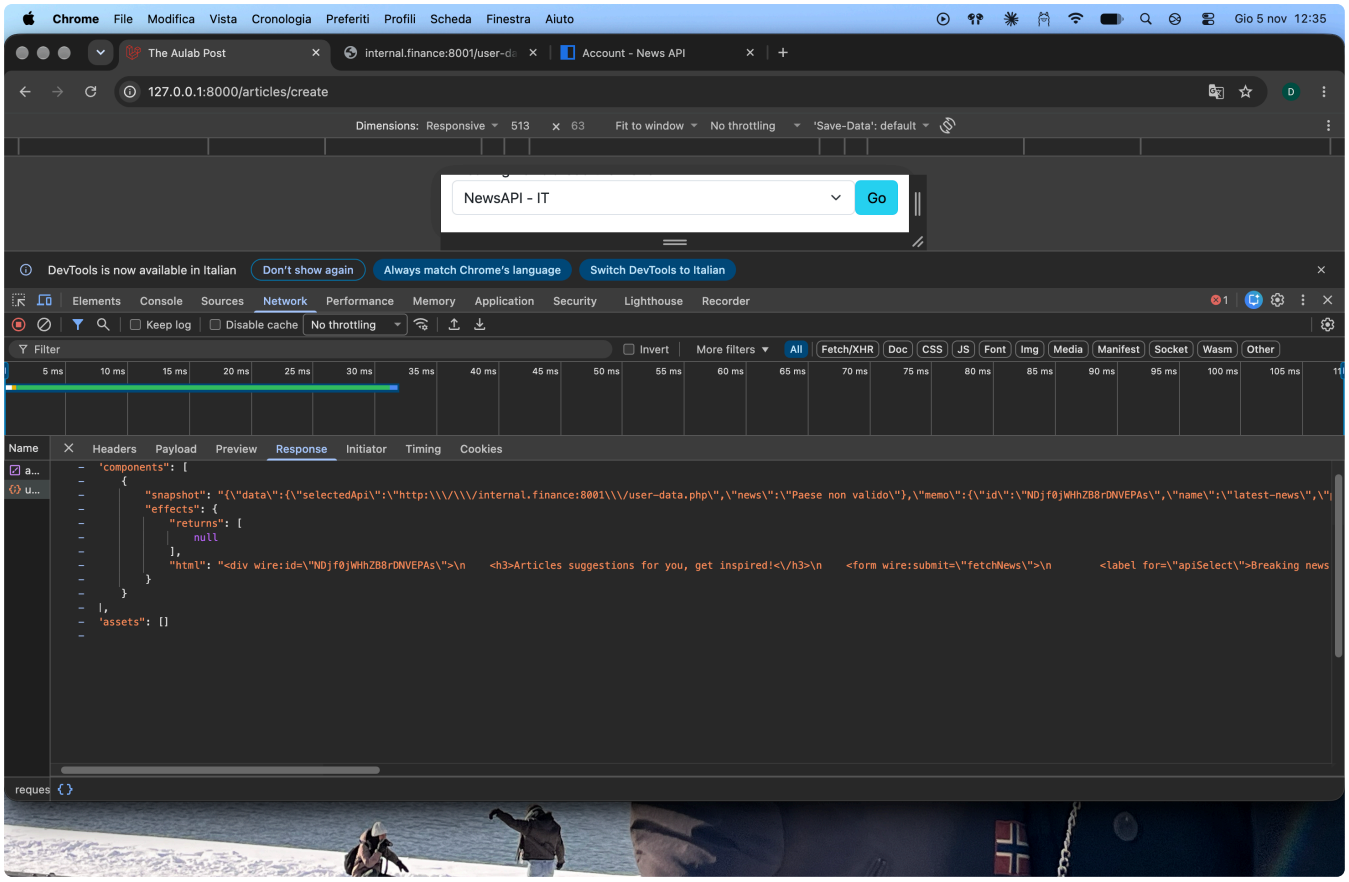
5. Verifica che l'attacco non riesca più

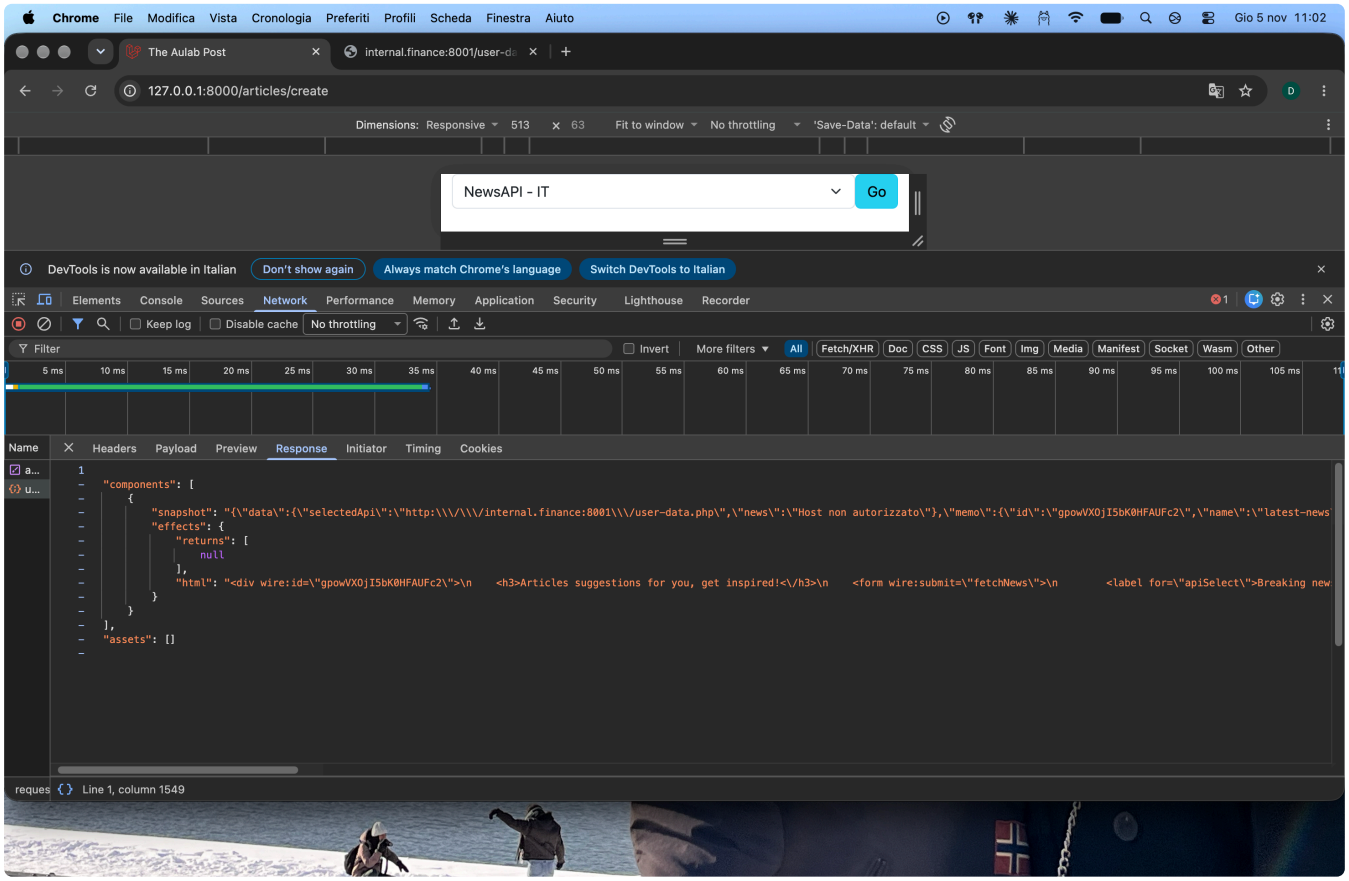
Sono stati eseguiti due test.

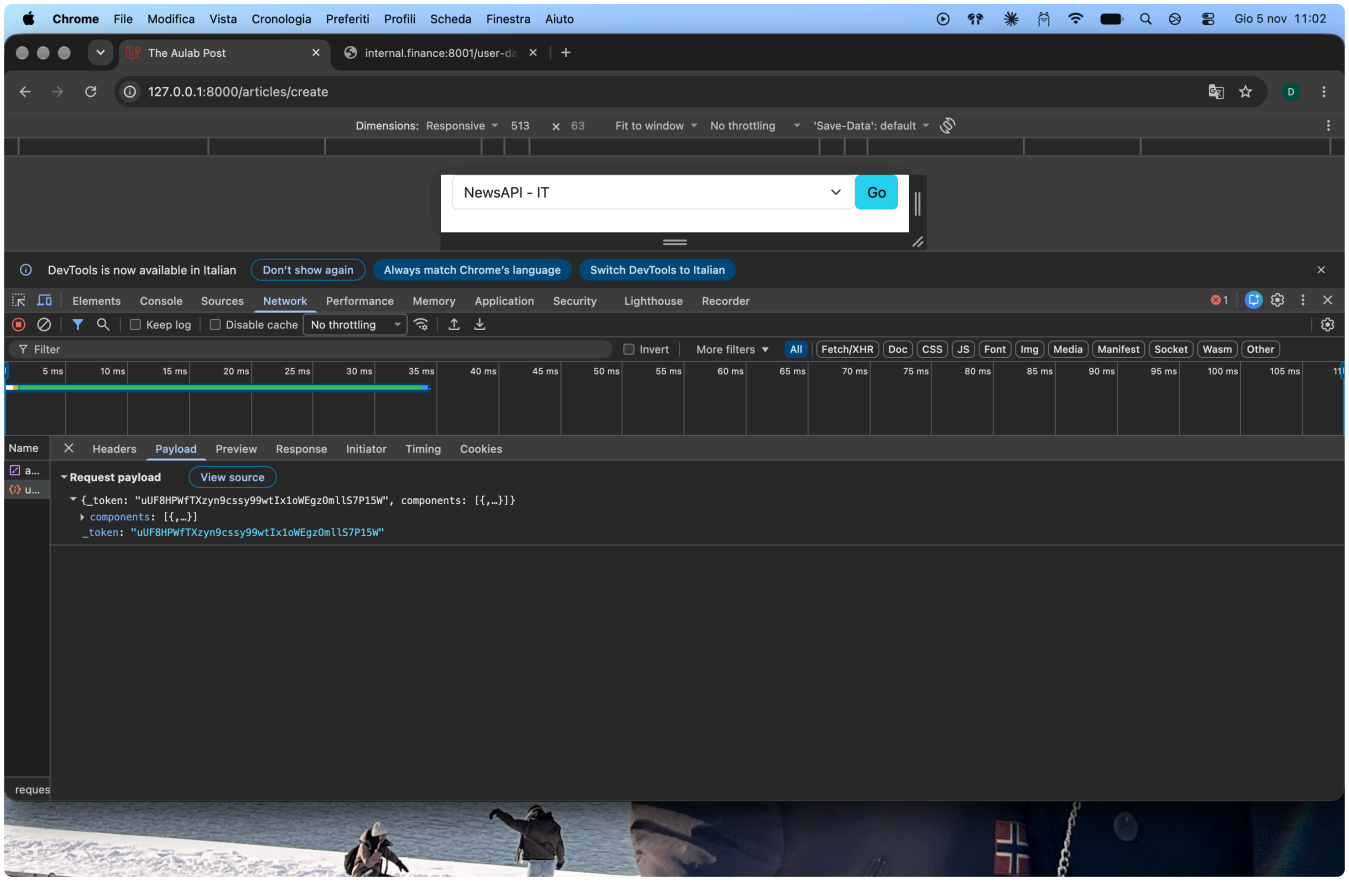
Funzionalità legittima intatta. Selezionata "NewsAPI - IT" (ora `value="it"`), risposta `{"status":"ok","totalResults":0,"articles":[]}` — la richiesta raggiunge regolarmente NewsAPI.

Attacco bloccato a più livelli.

- Rilanciando la manomissione della select con l'URL di `internal.finance:8001/user-data.php`, la risposta è `"news":"Paese non valido"` — il valore non corrisponde a nessuna chiave di `COUNTRY_ENDPOINTS`, quindi l'attacco viene fermato ancora prima di costruire un URL o contattare qualunque host (screenshot allegato).
- In una verifica precedente (prima del refactoring completo, con la sola allowlist attiva in `LatestNews.php`), lo stesso tentativo produceva `"news":"Host non autorizzato"` — a conferma che anche il solo strato di allowlist, da solo, sarebbe bastato a bloccare l'host non consentito (screenshot allegato).


Chrome File Modifica Vista Cronologia Preferiti Profili Scheda Finestra Aiuto
Gio 5 nov 12:35
The Aulab Post
internal.finance:8001/user-da
Account - News API
127.0.0.1:8000/articles/create
NewsAPI - IT
Go
DevTools is now available in Italian
Don't show again
Always match Chrome's language
Switch DevTools to Italian
Elements Console Sources Network Performance Memory Application Security Lighthouse Recorder
Name Headers Payload Preview Response Initiator Timing Cookies
"components": [
"snapshot": "{\"data\":{\"selectedApi\":\"http:\\\/\\\/internal.finance:8001\\\/user-data.php\",\"news\":\"Paese non valido\"},\"memo\":{\"id\":\"NDjf0jWHhZB8rDNVEPAs\",\"name\":\"latest-news\",
"effects": {
"returns": [
null
],
"html": "<div wire:id=\"NDjf0jWHhZB8rDNVEPAs\">\n <h3>Articles suggestions for you, get inspired!<\/h3>\n <form wire:submit=\"fetchNews\">\n <label for=\"apiSelect\">Breaking news
"assets": []


Chrome File Modifica Vista Cronologia Preferiti Profili Scheda Finestra Aiuto
Gio 5 nov 11:02
The Aulab Post
internal.finance:8001/user-da
127.0.0.1:8000/articles/create
NewsAPI - IT
Go
DevTools is now available in Italian
Don't show again
Always match Chrome's language
Switch DevTools to Italian
Elements Console Sources Network Performance Memory Application Security Lighthouse Recorder
Name Headers Payload Preview Response Initiator Timing Cookies
"components": [
"snapshot": "{\"data\":{\"selectedApi\":\"http:\\\/\\\/internal.finance:8001\\\/user-data.php\",\"news\":\"Host non autorizzato\"},\"memo\":{\"id\":\"gpowVXOjI5bK0HFAUFc2\",\"name\":\"latest-news
"effects": {
"returns": [
null
],
"html": "<div wire:id=\"gpowVXOjI5bK0HFAUFc2\">\n <h3>Articles suggestions for you, get inspired!<\/h3>\n <form wire:submit=\"fetchNews\">\n <label for=\"apiSelect\">Breaking new
"assets": []
Line 1, column 1549



In nessuno dei due casi i dati finanziari compaiono più nella risposta.